

考えるアシカ_成果物2_009_リスク管理表

リスク管理表

発生確率	説明
3	週に2回以上など高い頻度で発生する可能性がある
2	もしくは技術的難易度が高く、誤りを誘発しやすい状況である
1	3.1のどちらにも当てはまらない
1	半年に1回程度顕在化する可能性がある
1	もしくは技術的難易度が低く、発生する可能性が極めて低い

インパクト	説明
3	入場規制に関する要件を満たすことができず、補助金申請の認可に影響を及ぼす1日以上運用ができない状態が継続する
2	設置者・ユーザーに身体的・金銭的な損害を与える(長期的、または、50万円以上)
1	2.1, 3.0のどちらにも当てはまらない
1	リスクが顕在化しても運用にさほど影響がない(短時間の係員の案内で解消できる)

リスク管理ID	機能ID	機能名			想定されるリスク	リスクの範囲	発生確率	インパクト	算出したリスクレベル	リスク対策種別	リスク回避・軽減の方法	リスク抽出元
R-001	EK-100	入場管理機能	起動	入場管理起動	毎日5:00に実施される残数アイコン切替間値の取得タイミングで入場管理が起動していない場合、手動で取得できるか。	運用におけるリスク	1	1	1	設計フィードバック	考慮されていなければ対応いただく。	テストベース
R-002	Z1-202	残数表示インジケータ	情報表示	いまずく入場残数情報表示	発券機が非稼働状態になった場合は、障害発生とみなさず、残数表示インジケータの電源はOFFにしないという挙動となっている。 ハード故障などすぐに運用再開が難しい障害が発生した際に通常通りの表示となってしまうと、発券機付近に人が滞留し、混雑の原因となる可能性がある。	運用におけるリスク	2	1	2	設計フィードバック	今後のエンハンス対応として、発券機の障害種別により係員の操作により復旧可能な障害(つり抜け、つり結ばまりなど)とそうでない障害により差動をわけ、復旧困難な障害を識別しては残数表示インジケータでも障害発生として扱えるように検討いただく。	テストベース
R-003	Z2-202	残数表示インジケータ	情報表示	時間特別残数情報表示	同上	同上	-	-	-	-	同上	テストベース
R-004	Z1-203	残数表示インジケータ	情報表示	固定文言表示	固定文言に表示できない文字列が設定されており、起動するものの文言が正しく表示されない場合がある。	システムに対するリスク	1	1	1	テストフィードバック	前フェーズのテストにおいて考慮されていなかった追加いただく。	テストベース
R-005	EH-210	発券機機能	時間指定入場券	ログイン	ログイン用QRコード内の作成時刻、パスワードがハッシュ化できずあって、悪意をもった入場者により、なりすまログインされる懸念がある。	セキュリティにおけるリスク	2	2	4	テスト強化	生成されたログイン用QRコードを読み取り、QRコード仕様の通りにハッシュ化されていることを確認するテストを追加する。 類似の値が入場券のコードについてハッシュ化されるデータがあるため、同様にハッシュ化され不正が犯されていることをテストの中で確認する。	テストベース
R-006	EH-210	発券機機能	時間指定入場券	ログイン	異なるフォーマットのQRコードを読み取ったとき想定しないエラーが発生しないか。	システムにおけるリスク	3	2	6	テスト強化	ログイン用QRコードの形式ではないQRコードを読み取るテストを実施する。	テストベース
R-007	EH-210	発券機機能	時間指定入場券	ログイン	QRコードに埋め込まれた不正な構文(SQLインJECTION)により、秘匿化されるべきデータを表示できる懸念はないか。	セキュリティにおけるリスク	2	3	6	設計フィードバック	入力された文字列をサニタizingする処理が入っていないかは追加いただく。	テストベース
R-008	EH-210	発券機機能	時間指定入場券	ログイン	悪意を持ったユーザが何回もログインを試行してアカウント情報を奪取する操作を防止できないか。	セキュリティにおけるリスク	2	2	4	設計フィードバック	制限なくログインが実行できる仕組みになっている場合は、今後のエンハンス対応としてログイン回数制限を設けるとを検討いただく。	テストベース
R-009	EH-210	発券機機能	時間指定入場券	ログイン	他人の会員情報が表示されることはないか。	セキュリティにおけるリスク	1	2	2	テスト強化	複数の異なる会員情報を用いてログイン画面にログインした後に前回のログイン時のセッション情報が保持されていないことを確認するテストを追加する。	テストベース
R-010	EH-101	発券機機能	ナビゲーション	メニュー表示	「11_画面内チェックシステム要求仕様書」p.4「F21」「EK-210」時間特別残数情報取得より、発券機からの配信要求タイミングとして、以下の記述がある。 >開始画面(S-001-01)表示中に入場者が任意の操作を実施し、定期的な時間特別残数情報を行っていない場合、入場者が操作を行わない限り残数情報が更新されないため、前の開始時と時間特別残数情報がないまま、次の開始時に変わっても残数なしと表示され、本来購入できる入場券が購入できないと勘違いされる懸念がある。	事業におけるリスク	2	1	2	設計フィードバック テスト強化	開始画面の時間特別残数情報の取得タイミングにおいて確認する。 もし、時間特別残数情報を入場者の操作実施後に実行されていない場合は、定期的な情報更新が継続される。 また、時間特別残数情報の取得・残数による連携可否の処理については、テストのカバレッジを強化する。	テストベース
R-011	EH-101	発券機機能	ナビゲーション	メニュー表示	各発券機に対して、列を待たず順番待ちをするような表示方法をとった場合、既出オプションの時間特別残数が個数で下回ったタイミングで2号機・3号機の列に並んでいる未購入者が1号機に並び直しをする可能性がある。混雑・係員の誘導の手間が発生する懸念がある。	運用におけるリスク	3	1	3	運用フィードバック	事前にいまずく入場券は残数が少なならないように時間・機種では購入できないような警告の案内をわかりやすい位置に提示するなどの対応ができればいいかなどは追加いただく。	テストベース
R-012	EH-230	発券機機能	いまずく入場券	区分別購入枚数指定	既存システムからの汎用部分であり、発生する可能性は高いかと思われるが、金額の計算処理に誤りがあり、過大な差金損失の計算をしてしまう。その結果、差金損失や本来得られるべき利益の逸失が発生する懸念がある。	事業におけるリスク	1	3	3	テストフィードバック	画面内チェックシステムに閉じるスコープであるため、追加システム開発の差分で発生する可能性があるため、金額の計算ロジックに誤りがないことを確認するテストをテストを実施しているかたまたま開発担当者へ確認する。	テストベース
R-013	W-008	予約購入	-	-	同上	事業におけるリスク	2	3	6	テストフィードバック	Webチェックシステムに閉じるスコープであるため、Webチェックシステムの料金計算ロジックに誤りがないことを確認するテストを実施しているかDEAN2開発担当者へ確認する。	テストベース
R-014	EK-230	入場管理機能	時間特別残数通知	時間特別残数取得	新しい時間特別の開始時に行われる処理が複数存在し、ハードウェアの処理速度やネットワークの帯域の不足などにより、処理が遅延する可能性がある。 また、将来的に時間特別残数を増やし、購入可能な枚数が増えたときに、システムの負荷となる可能性がある。 ・入場管理の時間特別残数取得処理 ・入場管理で管理を引き継ぐ時間特別残数、次々々、さらにその次の時間特別残数取得の取得 ・入場ゲートの入場券情報一覧同期 ・状態が未使用のままだった入場券情報を無効にし、Webチェックシステムの予約管理DBサーバに送信する処理 ・新しい時間特別の入場券情報一覧を同期する処理	システムにおけるリスク	2	3	6	設計フィードバック	開始画面の上段まで購入した状態でのテストを実施し、処理に遅延が発生しないかを確認するパフォーマンステストを実施する。 また、将来的なスケール(時間特別残数の増加)に耐えられるようシステムアーキテクチャの見直しを検討いただく。 例えば、時間特別残数取得情報を読み取り、時間特別の開始時に実施しており、新しい時間特別の開始時にはその差分のみを取得することにより負荷低減させることを検討いただく。	テストベース
R-015	EG-220	入場ゲート機能	QRコード処理	QRコード有効/無効判定	上記と同様に、いまずく入場券の購入が同時に行われる場合に、ハードウェアの処理速度やネットワークの帯域の問題で、入場券情報の同期処理が遅延する可能性がある。	システムにおけるリスク	1	2	2	テスト強化	発券機から同時にいまずく入場券を購入した際、入場ゲートへの入場券情報同期処理が正常に行われていることを確認するテストを追加する。	UML
R-017	EK-230	入場管理機能	時間特別残数通知	時間特別残数取得	時間特別残数の計算処理や、購入No.の発券処理が間違っていると、販売可能な時間特別を販売してしまったり、販売可能な時間特別が満ちるのに販売終了してしまう。重複した購入No.の入場券が発券されるなどの問題が発生する可能性がある。	システムにおけるリスク	2	3	6	テスト強化	同時に購入を進めたり、購入と購入取消を同時に実行するなどの両面同時実行のテストを実施する。それらのテストのカバレッジを強化する。	テストベース
R-018	EN-241	発券機機能	いまずく入場券	現金支払い	支払い完了後、お釣りの取り忘れをする可能性がある。	利用におけるリスク	2	2	4	設計フィードバック	発券機とお釣りの払い出し処理が同じタイミングで行われている場合は、先にお釣りを払い出してから、発券機処理を行うよう順番を意図的に付くことでお釣りの取り忘れを抑止できる可能性があるため、処理タイミングについて検討いただく。 次回機器更新時、発券機に取り忘れ防止の注意を促すためのプラーを差込み、現金差戻時にプラーを差込ませることができるよう検討いただく。	テストベース
R-019	EN-241	発券機機能	いまずく入場券	現金支払い	途中まで金額を投入後、購入を取り消した場合、投入した金額が返却されたことに気づかず立ち去ってしまう可能性がある。	利用におけるリスク	2	2	4	設計フィードバック	取消ボタン押下後、すぐに画面遷移させずに購入ボタンを押したまま、お釣りの返却に初期画面に遷移することを検討いただく。	テストベース
R-020	EN-242	発券機機能	いまずく入場券	カード支払い	購入後、カードが返却されたことに気づかず立ち去ってしまう可能性がある。	利用におけるリスク	2	2	4	設計フィードバック	現金払いと同様に、取消ボタン押下後、すぐに画面遷移させ、先に現金を払い出してから、数秒経過後に初期画面に遷移することを検討いただく。	テストベース
R-021	EN-242 EH-244	発券機機能	いまずく入場券	カード支払い 非接触電子マネー支払い	現金払いやQRコード支払いでは、無操作時のタイムアウト処理について記述されているが、カード支払い・非接触電子マネー支払いではタイムアウトに関する記述がなく、購入操作を取り消さずにそのまま放置した場合、時間特別残数が確保された状態のままとなる可能性がある。	事業におけるリスク	2	2	4	設計フィードバック	カード支払い・非接触電子マネー支払いにおいても、無操作タイムアウトの実装を検討いただく。	テストベース
R-022	EH-311	発券機機能	発券処理(予約済)	ログイン	ソーシャルエンジニアリングにより、ログイン情報を取得される可能性がある。	セキュリティにおけるリスク	1	2	2	テスト強化 設計フィードバック	入力したパスワードのマスク処理(「*」で隠される)がされていることを確認するテストを追加する。 また、不正ログインを防止するために、2要素認証の導入を検討いただく。	テストベース
R-023	EH-400	発券機機能	共通機能	停止状態表示	システム構成要素の一つで障害が発生すると全機器が使用できなくなる仕様となっており、内容が混雑する可能性がある。	システムにおけるリスク	1	2	2	設計フィードバック	については、新しい時間特別の開始時、入場ゲートに入場券情報が同期されているため、入場させることができる可能性がある。 障害の発生箇所に応じて、稼働を継続するシステム構成要素を特定し、稼働を継続するアーキテクチャを考慮いただく。	テストベース
R-024	EH-400	発券機機能	共通機能	停止状態表示	30分以上障害が継続した場合、購入した入場券が入場できない可能性がある。	運用におけるリスク	1	2	2	設計フィードバック	障害発生時、動物園の係員が手動で入場券を取り消すことができるようにしているか確認いただく。	テストベース
R-025	EG-220	入場ゲート機能	QRコード処理	QRコード有効/無効判定	無効となった入場券が利用できた場合、制票人数以上の入場を許可してしまう可能性がある。	システムにおけるリスク	2	3	6	テスト強化	使用済みの入場券、使用しないまま時間特別が経過した入場券の利用ができないことを確認するテストを実施する。	テストベース
R-026	EH-900	発券機機能	終了	発券機停止	突発的な電源喪失が発生した場合、時間特別の確保がされず、入場券のいまずく入場券、ログインなしで入場し、時間特別の入場券の発券ができなくなる可能性がある。	システムにおけるリスク	1	2	2	テスト強化	突発的な電源喪失を想定したテストを実施する。	UML
R-027	W-001	新設装置	-	-	最大文字数・特殊文字を含めて登録を行った時に、インタフェース仕様の範囲(システム構成要素毎のデータの扱い)などでエラーが発生することはないか。 すでに登録済みのメールアドレスにて重複登録できることはないか。その結果、入場券情報の紐付けができず、購入した入場券が表示されないなどの状況が発生しないか。	システムにおけるリスク	2	2	2	テスト強化	会員登録・会員情報編集画面の入力文字列のエッジケースについて確認するテストを実施する。	テストベース
R-028	W-003	ログイン	-	-	画面内チェックシステムと同様にログイン・残数人が同時にログインした時に、セッション情報が混同されないか。	システムにおけるリスク	1	2	2	テスト強化	同時ログインにより、予約購入や予約購入履歴の表示、ログイン用QRコードの表示を行った時に、ログインしたユーザに紐づく情報が出力されることを確認するテストを実施する。	テストベース
R-029	W-008	予約購入	-	-	残数不足により購入が成立しなかった場合に決済処理の取り直しを行う必要があるが、処理が失敗し、購入が完了していないに陥ってしまうリスクが発生する可能性がある。	システムにおけるリスク	2	3	6	テスト強化	購入時、時間特別残数が不足している際にも購入が完了しないことを確認するテストを実施する。	テストベース
R-030	-	全般	-	-	使用しているライブラリやフレームワークに脆弱性があった場合、攻撃者によって個人情報や決済情報を窃取される可能性がある。	システムにおけるリスク	2	3	6	テスト強化	Web脆弱性診断、ペネトレーションテストを実施する。	テストベース

考えるアシカ_成果物2_009_リスク管理表

R-031	EH-220	発券機能	時間指定入場券	入場時間枠選択	ボタン制御が不十分で、過去の時間枠が選択できてしまう。画面操作中に時間枠が変化したが、画面上では開始後の時間枠が選択できてしまう可能性がある。	システムにおけるリスク	2	2	4	テスト強化	販売終了した時間枠が選択できないことを確認するテストを実施する。	生成AI
R-032	EH-220	発券機能	時間指定入場券	入場時間枠選択	残数表示の「○」「×」「↓」などの記号について、国ごとの慣習の違いが起因して利用者によっては意味を誤解する可能性がある。	システムにおけるリスク	1	1	1	設計フィードバック	画面内に残数アイコンの凡例を示すことで、誤解を防ぐような対応ができないか検討いただく。	生成AI
R-033	W-001	新規登録	-	-	「21 Webチケットシステム要求仕様書.pdf」において、新規登録時のパスワード文字数に関する要件が記述されていない。短いパスワードを登録してしまうと、アカウント不正ログインの可能性が高まる懸念がある。	セキュリティにおけるリスク				設計フィードバック	パスワードの文字数、文字種(英字/数字/記号)の混在、大文字小文字の混在など複雑なパスワードを設定することを促すための入力バリデーションの追加を検討いただく。	テストベース